

본 데이터 처리 부록(이하 "DPA")은 2025 년 11 월 6 일자로 체결되며,

[알파넥스트 주식회사] (이하 "컨트롤러") 주소: 서울특별시 강남구 테헤란로 123,
알파타워 25 층 사업자등록번호: 123-45-67890 대표이사: 김영준

와(과)

[베타솔루션즈 유한회사] (이하 "프로세서") 주소: 경기도 성남시 분당구 판교역로 235,
베타빌딩 10 층 사업자등록번호: 098-76-54321 대표이사: 이수진

(이하 "컨트롤러"와 "프로세서"를 개별적으로 "당사자", 총칭하여 "양 당사자"라 함)

간에 체결된 [서비스 제공 기본 계약서] (이하 "주 계약")의 일부를 구성한다.

전문

컨트롤러는 프로세서에게 주 계약에 명시된 서비스(이하 "서비스")를 제공받는 과정에서,
컨트롤러가 수집 및 통제하는 특정 개인정보(이하 "개인정보")의 처리를 위탁한다.

양 당사자는 유럽 연합의 일반 개인정보 보호 규정(Regulation (EU) 2016/679, 이하
"GDPR") 및 대한민국의 개인정보 보호법(이하 "K-PIPA"), 그리고 기타 적용 가능한 모든
개인정보 보호 법규(이하 총칭하여 "데이터 보호법")를 준수하기 위해 본 DPA 를
체결한다.

본 DPA 는 주 계약에 우선하며, 본 DPA 의 조항과 주 계약의 조항이 상충하는 경우,
개인정보 보호와 관련된 사항에 한하여 본 DPA 의 조항이 우선적으로 적용된다.

제 1 조 (정의)

본 DPA 에서 사용되는 용어는 데이터 보호법에서 정의된 의미를 가지며, 그 외 용어는
다음과 같이 정의한다.

1.1. "개인정보"라 함은, 식별되었거나 식별 가능한 자연인("데이터 주체")에 관한 모든
정보를 의미하며, 구체적인 처리 대상 데이터는 본 DPA [별첨 1]에 명시된 바와 같다.

1.2. "컨트롤러", "프로세서", "데이터 주체", "개인정보 침해", "처리", "감독 기관" 등은
GDPR 제 4 조 또는 K-PIPA 제 2 조에서 정의된 의미를 갖는다.

1.3. "하위 처리자(Sub-processor)"라 함은, 프로세서가 본 DPA 에 따른 처리 활동의 일부를
수행하기 위해 고용한 제 3 자 업체를 의미한다.

1.4. "표준 계약 조항(SCC)"이라 함은, 유럽 집행위원회가 GDPR 제 46 조 제 2 항 c)호에 따라 채택한 표준 개인정보 보호 조항(예: Commission Implementing Decision (EU) 2021/914) 또는 대한민국 개인정보보호위원회가 승인한 표준 계약 조항을 의미한다.

1.5. "기술적 및 조직적 보안 조치(TOMS)"라 함은, 개인정보를 우발적이거나 불법적인 파괴, 분실, 변경, 무단 공개 또는 접근으로부터 보호하기 위해 구현된 조치를 의미하며, 구체적인 내용은 [별첨 2]에 명시된다.

제 2 조 (DPA 의 적용)

2.1. 본 DPA 는 프로세서가 컨트롤러를 대신하여 개인정보를 처리하는 모든 활동에 적용된다.

2.2. 주 계약이 종료, 만료 또는 갱신되더라도, 프로세서 또는 그 하위 처리자가 컨트롤러의 개인정보를 보유하거나 처리하는 한 본 DPA 는 유효하게 존속한다.

제 3 조 (처리 목적 및 범위)

3.1. 프로세서는 오직 컨트롤러의 문서화된 지침(이하 "지침")에 따라서만 개인정보를 처리해야 한다. 본 DPA 및 주 계약은 컨트롤러의 초기 지침을 구성한다.

3.2. 컨트롤러는 서비스 이용 과정에서 추가적인 지침을 제공할 수 있으며, 프로세서는 해당 지침이 데이터 보호법을 위반한다고 판단하지 않는 한 이를 준수해야 한다. 만약 프로세서가 지침이 법규를 위반한다고 판단하는 경우, 해당 지침을 이행하기 전에 즉시 컨트롤러에게 이를 통지해야 한다.

3.3. 본 DPA 에 따라 처리되는 개인정보의 상세 내역(데이터 주체의 범주, 개인정보의 유형, 처리의 성격 및 목적, 처리 기간 등)은 [별첨 1]에 상술한다.

3.4. 프로세서는 컨트롤러의 사전 서면 동의 없이는 [별첨 1]에 명시된 목적을 벗어나 어떠한 방식으로든 개인정보를 처리(제 3 자 제공, 마케팅 활용, 익명화 또는 가명화 데이터의 자체 활용 등 포함)할 수 없다.

제 4 조 (컨트롤러의 의무)

4.1. 컨트롤러는 프로세서에게 제공하는 개인정보의 수집 및 처리가 적법한 근거(동의, 계약 이행, 정당한 이익 등)에 기반함을 보장한다.

4.2. 컨트롤러는 데이터 주체에게 적절한 고지(개인정보 처리방침 등)를 제공했음을 보장한다.

4.3. 컨트롤러는 본 DPA [별첨 1]에 기술된 처리 활동의 정확성 및 완전성에 대한 책임을 진다.

4.4. 컨트롤러는 프로세서가 본 DPA 를 준수할 수 있도록 명확하고 시의적절한 지침을 제공할 책임을 진다.

제 5 조 (하위 처리자)

5.1. 프로세서는 컨트롤러의 구체적인 사전 서면 승인 없이는 어떠한 하위 처리자에게도 개인정보 처리를 위탁할 수 없다.

5.2. (독소 조항 1: 광범위한 하위 처리자 포괄 동의) 전항에도 불구하고, 컨트롤러는 본 DPA 의 체결로써 프로세서가 [별첨 3]에 기재된 하위 처리자 목록(이하 "승인된 하위 처리자 목록")을 이용하는 것에 대해 포괄적으로 사전 동의한 것으로 간주한다. 또한, 컨트롤러는 프로세서가 비즈니스 효율성 및 서비스 품질 개선을 위해 합리적인 판단에 따라 향후 지정하는 모든 하위 처리자의 이용에 대해서도 본 계약을 통해 일반적인 승인을 부여한 것으로 본다.

5.3. 프로세서는 새로운 하위 처리자를 추가하거나 기존 하위 처리자를 변경하고자 하는 경우, 변경 사항이 적용되기 최소 14 일 전에 컨트롤러에게 이메일 또는 서비스 내 공지를 통해 해당 사실을 통지한다. 컨트롤러가 통지 수령 후 7 일 이내에 데이터 보호법에 근거한 합리적인 이유를 제시하며 서면으로 반대하지 않는 경우, 해당 변경은 승인된 것으로 간주한다.

5.4. 컨트롤러가 합리적인 이유로 반대하는 경우, 양 당사자는 문제를 해결하기 위해 성실히 협의한다. 만약 협의가 이루어지지 않는 경우, 컨트롤러는 주 계약을 위약금 없이 해지할 수 있는 권리를 가진다.

5.5. 프로세서는 모든 하위 처리자와 본 DPA 에 규정된 것과 실질적으로 동일하거나 그 이상의 수준의 개인정보 보호 의무를 부과하는 서면 계약을 체결해야 한다.

5.6. 프로세서는 하위 처리자의 작위 또는 부작위로 인해 발생하는 모든 개인정보 보호 의무 위반에 대해 컨트롤러에 대해 전적인 책임을 진다. 이는 마치 프로세서 자신이 직접 해당 위반 행위를 한 것과 동일한 책임을 부담함을 의미한다.

제 6 조 (데이터 주체의 권리)

6.1. 프로세서는 처리되는 개인정보의 성격을 고려하여, 컨트롤러가 데이터 주체의 권리(접근, 정정, 삭제, 처리 제한, 이동, 반대 등) 요청에 대응할 수 있도록 적절한 기술적, 관리적 조치를 통해 컨트롤러를 지원해야 한다.

6.2. 프로세서는 데이터 주체로부터 직접 권리 요청을 받은 경우, 해당 요청을 처리하지 않고 즉시(최대 72 시간 이내) 컨트롤러에게 전달해야 한다.

6.3. (독소 조항 2: 데이터 주체 권리 대응 비용 전가) 전항에 따른 요청 전달 외에, 컨트롤러가 제 6.1 조에 따른 지원을 요청하는 경우, 프로세서는 해당 요청에 대응하는 데 필요한 최소한의 협력(예: 관련 데이터 검색 및 제공)만을 제공한다. 이 과정에서 발생하는 모든 추가적인 비용, 인력 투입 및 기술적 지원에 대한 비용은 컨트롤러의 지침에 따른 추가 업무로 간주되어, 프로세서가 사전에 고지하는 별도의 요율에 따라 컨트롤러가 전액 부담한다.

제 7 조 (보안 조치)

7.1. (독소 조항 3: 보안 조치 일방 변경권) 프로세서는 [별첨 2]에 명시된 기술적 및 조직적 보안 조치(TOMS)를 이행하고 유지해야 한다. 프로세서는 법규 변경, 기술 발전, 또는 자사의 비즈니스 환경 변화를 반영하기 위해 언제든지 단독 재량으로 본 [별첨 2]의 보안 조치를 수정, 변경 또는 대체할 수 있다. 단, 이러한 변경이 DPA 발효 시점의 전반적인 보안 수준을 "중대하게" 저하시켜서는 아니 된다. 프로세서는 이러한 변경 사항을 자사 웹사이트에 게시하거나 이메일을 통해 컨트롤러에게 통지할 수 있다.

7.2. 프로세서는 개인정보를 처리하는 모든 임직원, 계약자 및 대리인이 기밀유지 의무(법적 의무 또는 서약)를 준수하도록 보장해야 한다.

7.3. 프로세서는 개인정보에 접근할 수 있는 인력을 업무상 필요한 최소한의 인원("Need-to-Know" 원칙)으로 제한하고, 해당 인력에게 정기적인 개인정보 보호 및 보안 교육을 실시해야 한다.

7.4. 프로세서는 데이터 보호법에서 요구하는 경우, 개인정보 보호 영향 평가(DPIA) 및 감독 기관과의 사전 협의와 관련하여 컨트롤러에게 합리적인 지원을 제공해야 한다.

제 8 조 (개인정보 침해)

8.1. 프로세서는 개인정보 침해 사실을 인지한 경우, 부당한 지체 없이, 그리고 어떠한 경우에도 인지 후 48 시간 이내에 컨트롤러에게 서면으로 통지해야 한다.

8.2. 해당 통지에는 최소한 다음 정보가 포함되어야 하며, 정보가 즉시 확보되지 않는 경우 단계적으로 제공되어야 한다. a) 침해의 성격 (영향을 받은 데이터 주체의 범주 및 대략적인 수, 관련 개인정보 기록의 범주 및 대략적인 수 포함) b) 프로세서의 개인정보 보호 책임자(DPO) 또는 담당자의 연락처 c) 침해로 인해 발생할 수 있는 예상되는 결과 d) 침해를 해결하고 그 잠재적인 부정적 영향을 완화하기 위해 프로세서가 취했거나 취할 예정인 조치

8.3. 프로세서는 컨트롤러가 데이터 보호법에 따른 침해 통지 의무(감독 기관 및 데이터 주체에 대한 통지)를 이행할 수 있도록 합리적인 지원을 제공해야 한다.

8.4. 프로세서는 모든 침해 사고의 사실, 영향 및 시정 조치를 문서화하고, 컨트롤러의 요청 시 이를 제공해야 한다.

8.5. 침해 사고의 원인이 프로세서의 본 DPA 위반 또는 고의, 과실에 기인하는 경우, 프로세서는 컨트롤러가 침해 사고를 조사하고 대응하는 데 소요된 합리적이고 직접적인 비용(법률 자문 비용, 포렌식 비용 등)을 부담한다.

제 9 조 (감사 및 검증)

9.1. 프로세서는 컨트롤러가 본 DPA 에 따른 의무 준수 여부를 합리적으로 검증할 수 있도록 필요한 모든 정보(예: 최신 보안 인증서 사본 - ISO 27001, SOC 2 Type II 등, 관련 정책 문서)를 제공해야 한다.

9.2. (독소 조항 4: 감사 권한의 과도한 제한) 컨트롤러의 현장 감사 권한은 다음과 같이 엄격히 제한된다. 컨트롤러는 프로세서가 선임한 독립적인 제 3 자 감사인이 작성한 감사 보고서(또는 SOC 2 보고서 등의 요약본)를 연 1 회 검토하는 것으로 감사를 갈음하는 데 동의한다. 컨트롤러가 프로세서의 중대한 DPA 위반을 입증할 수 있는 구체적이고 객관적인 증거를 제시하는 경우에 한하여, 컨트롤러는 직접 현장 감사를 요청할 수 있다. 이 경우 감사는 (a) 최소 60 일 전 서면 통지, (b) 프로세서의 정상적인 영업 시간 중에 수행, (c) 연 1 회를 초과할 수 없으며, (d) 프로세서의 영업 비밀, 기밀 정보 또는 다른 고객의 데이터를 침해하지 않는 범위로 엄격히 제한되고, (e) 감사의 모든 비용은 컨트롤러가 부담한다.

제 10 조 (데이터의 국외 이전)

10.1. (독소 조항 5: 데이터 국외 이전 포괄 동의) 컨트롤러는 프로세서가 서비스를 제공하기 위한 목적으로, 유럽경제지역(EEA) 또는 대한민국 외부의 국가(이하 "제 3 국")로 개인정보를 이전할 필요가 있음을 인정하고 이에 포괄적으로 동의한다. 이는 프로세서의 글로벌 계열사, 파트너사 및 하위 처리자가 위치한 모든 국가(해당 국가가 유럽 집행위원회나 대한민국 개인정보보호위원회의 적정성 결정을 받지 못한 경우 포함)로의 이전을 포함한다.

10.2. 제 3 국으로의 이전에 대해 적정성 결정이 없는 경우, 프로세서는 해당 이전이 표준 계약 조항(SCC) 또는 기타 데이터 보호법이 인정하는 적법한 이전 메커니즘에 따라 수행됨을 보장... (하려고 노력한다.) (-> 의도적으로 문장 종결을 모호하게 함)

10.3. 프로세서는 컨트롤러의 요청 시, 적용된 이전 메커니즘에 대한 증빙 자료(예: 체결된 SCC 사본, 단, 상업적으로 민감한 정보는 삭제)를 제공한다.

제 11 조 (책임 및 면책)

11.1. 각 당사자는 본 DPA 위반으로 인해 상대방이 입은 직접적인 손해에 대해 책임을 진다.

11.2. (독소 조항 6: 광범위한 면책 (중과실 포함)) 어떠한 경우에도 프로세서, 그 계열사, 임직원 및 하위 처리자는 데이터 보호법 위반, 본 DPA 위반, 또는 서비스 제공과 관련하여 발생하는 모든 종류의 간접적, 특별, 부수적, 결과적, 징벌적 손해(이익 손실, 데이터 손실, 영업권 손실 등 포함)에 대해 책임을 지지 않는다. 또한, 프로세서는 본 DPA에 따른 의무 이행에 있어 경미한 과실뿐만 아니라, 명백한 고의가 아닌 중대한 과실로 인해 발생한 손해에 대해서도 책임을 지지 않는다.

11.3. (참조 교란: 이 조항은 아래 부칙 [별첨 2] 제 5 항으로 이동됨) (이동 전 원문: 프로세서의 본 DPA 또는 주 계약에 따른 총 누적 책임 한도는, 어떠한 경우에도, 손해배상 청구의 원인이 된 사건 발생 직전 1 개월 동안 컨트롤러가 프로세서에게 실제로 지급한 서비스 수수료의 합계 또는 일천만원(10,000,000 KRW) 중 더 적은 금액을 초과할 수 없다.)

11.4. (독소 조항 7: 짧은 청구 기간) 컨트롤러는 손해 발생 사실 또는 DPA 위반 사실을 알게 된 날로부터 3 개월 이내에 프로세서에게 서면으로 구체적인 손해배상 청구를 제기해야 하며, 이 기간 내에 청구하지 않을 경우 해당 손해에 대한 모든 청구 권리를 영구히 포기한 것으로 간주한다.

11.5. 컨트롤러는 (a) 컨트롤러의 DPA 또는 데이터 보호법 위반, (b) 컨트롤러의 지침 이행, (c) 컨트롤러가 제공한 데이터의 부정확성으로 인해 발생하는 모든 제 3 자(데이터 주체, 감독 기관 포함)의 청구, 소송, 손실, 벌금으로부터 프로세서를 방어하고 면책하며 손해를 배상해야 한다.

제 12 조 (계약 기간 및 종료)

12.1. 본 DPA 는 주 계약의 발효일로부터 효력을 발생하며, 주 계약이 종료되거나 만료될 때까지 유효하다.

12.2. (독소 조항 8: 자동 갱신 및 해지 제한) 주 계약은 명시된 기간 만료 시 동일한 기간으로 자동 갱신되며, 어느 일방이 계약 만료일로부터 최소 6 개월 전에 갱신을 원하지 않는다는 명시적인 서면 통지를 하지 않는 한 유효하게 연장된다.

12.3. 주 계약 종료 또는 만료 시, 컨트롤러는 30 일 이내에 프로세서에게 개인정보의 (a) 반환 또는 (b) 삭제를 서면으로 요청해야 한다. 컨트롤러가 이 기간 내에 명시적인 요청을 하지 않는 경우, 프로세서는 법적 보관 의무가 없는 한, 해당 개인정보를 자사의 표준 데이터 파기 절차에 따라 즉시 또는 합리적인 기간 내에 복구 불가능한 방법으로 파기할 수 있으며, 이에 대해 어떠한 책임도 지지 않는다.

12.4. 데이터 반환 또는 삭제 시 발생하는 비용은 컨트롤러가 부담한다.

12.5. 제 7 조(보안 조치 - 기밀유지 부분), 제 11 조(책임 및 면책), 제 13 조(기밀유지), 제 14 조(준거법 및 재판 관할) 및 기타 그 성질상 존속이 필요한 조항들은 본 DPA 종료 후에도 유효하게 존속한다.

제 13 조 (기밀유지)

13.1. 각 당사자는 본 DPA 및 주 계약의 이행과 관련하여 알게 된 상대방의 모든 기밀 정보(개인정보 포함)를 기밀로 유지해야 한다.

13.2. 기밀 정보는 법원, 정부 기관 또는 감독 기관의 적법한 명령에 따라 공개가 요구되는 경우를 제외하고는 상대방의 사전 서면 동의 없이 제 3 자에게 공개되어서는 아니 된다.

13.3. 공개가 요구되는 경우, 해당 당사자는 법이 허용하는 범위 내에서 상대방에게 즉시 통지하여 적절한 보호 조치를 취할 기회를 제공해야 한다.

제 14 조 (준거법 및 재판 관할)

14.1. 본 DPA 는 대한민국 법률에 따라 규율되고 해석된다.

14.2. 본 DPA 와 관련하여 발생하는 모든 분쟁, 논쟁 또는 청구는 서울중앙지방법원을 제 1 심 전속적 합의 관할 법원으로 하여 해결한다.

14.3. 전항에도 불구하고, GDPR 과 관련된 분쟁의 경우, 데이터 주체는 관련 데이터 보호법에 따라 관할 감독 기관에 불만을 제기하거나 관할 법원에 소송을 제기할 권리를 보유한다.

제 15 조 (일반 조항)

15.1. (완전 합의) 본 DPA 및 주 계약, 그리고 그 부칙들은 양 당사자 간의 완전한 합의를 구성하며, 이전에 이루어진 모든 구두 또는 서면 합의를 대체한다.

15.2. (수정) 본 DPA 의 모든 수정 또는 변경은 양 당사자의 정당한 대표자가 서명한 서면 합의서에 의해서만 효력을 갖는다. (단, 제 7.1 조 및 제 5.2 조의 예외 참조)

15.3. (양도) 어느 당사자도 상대방의 사전 서면 동의 없이 본 DPA 상의 권리나 의무를 양도할 수 없다. 단, 프로세서는 인수, 합병, 또는 자산의 전부나 실질적인 전부의 매각과 관련하여 컨트롤러에게 서면 통지함으로써 본 DPA 를 양도할 수 있다.

15.4. (통지) 본 DPA 에 따른 모든 통지는 본 DPA 서두에 기재된 주소로 등기 우편 또는 이메일(수신 확인 증빙 필요)로 발송되어야 하며, 수신된 시점에 도달한 것으로 간주한다.

15.5. (권리 불포기) 어느 일방이 본 DPA 상의 권리를 행사하지 않거나 지연하더라도 이를 해당 권리의 포기로 간주하지 않으며, 일회성 또는 부분적 권리 행사가 다른 권리나 추가적인 권리 행사를 방해하지 않는다.

15.6. (분리 가능성) 본 DPA 의 특정 조항이 관할 법원에 의해 무효이거나 집행 불가능한 것으로 판명되더라도, 나머지 조항들의 유효성 및 집행 가능성에는 영향을 미치지 아니한다. 양 당사자는 해당 무효 조항을 원래의 의도에 가장 근접한 유효한 조항으로 대체하기 위해 성실히 협의한다.

본 DPA 를 증명하기 위해, 정당하게 권한을 위임받은 양 당사자의 대표가 아래 서명란에 기명날인함으로써 본 DPA 가 2025 년 11 월 6 일자로 발효됨을 확인한다.

컨트롤러 (Controller) 알파넥스트 주식회사

서명: _____ 성명: 김영준 직위: 대표이사 일자: 2025 년 11 월 6 일

프로세서 (Processor) 베타솔루션즈 유한회사

서명: _____ 성명: 이수진 직위: 대표이사 일자: 2025 년 11 월 6 일

[별첨 1] 개인정보 처리 활동의 상세 내역

A. 컨트롤러 (알파넥스트 주식회사) 알파넥스트 주식회사는 [온라인 커머스 플랫폼 "알파몰"]을 운영하는 사업자이다.

B. 프로세서 (베타솔루션즈 유한회사) 베타솔루션즈 유한회사는 [클라우드 기반 CRM 솔루션 및 마케팅 자동화 서비스 "베타 CRM"]을 제공하는 사업자이다.

C. 처리의 성격 및 목적 프로세서는 컨트롤러의 고객 관계 관리(CRM), 타겟 마케팅 캠페인 수행, 고객 서비스 지원, 구매 행동 분석 및 서비스 이용 통계 분석을 목적으로 개인정보를 처리(저장, 분석, 분류, 전송, 조회 등)한다.

D. 처리 기간 본 DPA 및 주 계약의 유효 기간 동안. 계약 종료 시 제 12.3 조에 따른다.

E. 데이터 주체의 범주 컨트롤러의 온라인 커머스 플랫폼("알파몰")을 이용하는 회원 및 비회원 고객, 마케팅 수신 동의자, 고객 서비스 문의자.

F. 처리되는 개인정보의 유형

1. 식별 정보:

- 성명, 아이디, 비밀번호(암호화), 생년월일, 성별, 연락처(휴대폰 번호, 이메일 주소), CI/DI

2. 배송 정보:

- 수취인 성명, 연락처, 주소

3. 서비스 이용 정보:

- 주문 내역 (상품명, 주문 번호, 결제 금액, 결제 수단)
- 로그 기록, 쿠키, 접속 IP 정보, 기기 정보 (OS, 브라우저 유형)
- 서비스 이용 시간, 방문 기록, 검색어
- 고객 상담 내역 (전화 녹취, 채팅 기록, 이메일 문의)

4. 마케팅 정보:

- 마케팅 수신 동의 여부 (이메일, SMS, 앱 푸시)
- 캠페인 반응 이력

G. 민감 정보의 처리 (해당 시)

- (처리 없음)
- 만약 처리가 있다면: [구체적인 민감 정보 유형 및 처리 목적 명시] - 본 계약에서는 해당 사항 없음.

[별첨 2] 기술적 및 조직적 보안 조치 (TOMS)

프로세서는 개인정보의 보안 및 기밀성을 보장하기 위해 다음을 포함하되 이에 국한되지 않는 조치를 이행하고 유지한다.

1. 접근 통제 (Access Control) 1.1. 물리적 접근 통제: 데이터 센터 및 사무실에 대한 접근을 인가된 인력으로 엄격히 제한하며, 24/7 보안 감시, 접근 카드 리더, 생체 인식(해당 시), 방문자 기록 관리 시스템을 운영한다. 1.2. 논리적 접근 통제: a) 역할 기반 접근 통제(RBAC)를 구현하여 사용자의 직무에 따라 시스템 및 데이터에 대한 접근 권한을 최소한으로 부여("최소 권한의 원칙")한다. b) 고유한 사용자 ID를 발급하고, 강력한 비밀번호 정책(복잡성, 주기적 변경)을 시행한다. c) 다중 인증(MFA)을 주요 시스템 접근 시 의무화한다. d) 인사 이동(입/퇴사, 직무 변경) 시 접근 권한을 즉시 검토하고 변경(생성, 수정, 삭제)하는 절차를 수립한다. e) 원격 접근 시 VPN 등 안전한 보안 채널을 사용하도록 강제한다.
2. 데이터 암호화 (Encryption) 2.1. 전송 중 암호화 (Encryption in Transit): 모든 외부 네트워크를 통한 개인정보 전송 시 최신 표준 암호화 프로토콜(예: TLS 1.2 이상, HTTPS, SFTP)을 사용한다. 2.2. 저장 시 암호화 (Encryption at Rest): 데이터베이스, 스토리지, 백업 미디어에 저장되는 개인정보(특히 식별 정보, 비밀번호 등 주요 정보)는 강력한 표준 알고리즘(예: AES-256)을 사용하여 암호화한다. 2.3. 키 관리: 암호화 키는 안전한 키 관리 시스템(KMS)을 통해 생성, 저장, 배포 및 폐기하며, 키에 대한 접근은 엄격히 통제한다.
3. 시스템 보안 및 무결성 (System Security and Integrity) 3.1. 방화벽 및 네트워크 분리: 외부 침입을 차단하기 위해 방화벽, 침입 탐지 시스템(IDS) 및 침입 방지 시스템(IPS)을 운영하며, 네트워크 망을 분리(예: DMZ, 운영망, 개발망)하여 내부 시스템을 보호한다. 3.2. 악성코드 방지: 모든 서버, 엔드포인트 및 시스템에 최신

백신 소프트웨어 및 악성코드 탐지 솔루션을 설치하고 실시간 감시 및 정기 검사를 수행한다. 3.3. **취약점 관리:** 정기적인 보안 취약점 스캔 및 모의 해킹을 수행하고, 식별된 취약점에 대해 위험 등급에 따라 신속하게 패치 및 보완 조치를 적용한다.

3.4. **보안 구성:** 시스템 및 애플리케이션은 보안 강화 설정(Hardening) 가이드라인에 따라 구성한다.

4. **로그 기록 및 모니터링 (Logging and Monitoring)** 4.1. 개인정보 처리 시스템에 대한 주요 접근 및 활동(읽기, 쓰기, 삭제 등) 로그를 생성하고, 해당 로그를 위변조 방지 조치를 적용하여 안전하게 보관(최소 1년 이상, 법규 준수)한다. 4.2. 보안 이벤트 모니터링 시스템(SIEM 등)을 통해 로그를 실시간으로 분석하고, 비정상적인 활동이나 잠재적인 보안 위협을 탐지 및 경고하는 체계를 갖춘다.
5. **(독소 조항 8: 참조 교란 및 배상책임 상한) 책임의 제한:** 본 [별첨 2]에 명시된 보안 조치의 이행에도 불구하고 발생하는 모든 보안 사고 또는 데이터 유출에 대해, 프로세서는 컨트롤러가 입증한 직접적인 손해에 대해서만 책임을 진다. 어떠한 경우에도, 본 DPA 또는 주 계약(본 [별첨 2]의 위반 포함)과 관련하여 발생하는 프로세서의 총 누적 책임 한도는, 청구 원인(계약 위반, 불법 행위, 과실 등)이나 소송 형태와 관계없이, 해당 청구의 원인이 된 사건 발생 직전 1개월 동안 컨트롤러가 프로세서에게 주 계약에 따라 실제로 지급한 서비스 수수료의 총액 또는 일천만원(10,000,000 KRW) 중 더 적은 금액을 초과할 수 없다. 컨트롤러는 이 한도를 초과하는 모든 손해에 대한 청구권을 포기한다. (제 11 조 제 3 항에서 이동됨)
6. **데이터 백업 및 복구 (Backup and Recovery)** 6.1. 개인정보 및 시스템의 가용성과 무결성을 보장하기 위해 정기적인 데이터 백업을 수행한다. 6.2. 백업 데이터는 원본과 물리적으로 분리된 안전한 장소(오프사이트 또는 별도 클라우드 스토리지)에 보관하며, 암호화하여 보호한다. 6.3. 재해 또는 장애 발생 시 신속하게 서비스를 복구할 수 있도록 비즈니스 연속성 계획(BCP) 및 재해 복구(DR) 계획을 수립하고, 정기적으로 테스트한다.
7. **개인정보 파기 (Data Destruction)** 7.1. 보유 기간이 경과하거나 처리 목적이 달성된 개인정보는 복구 또는 재생이 불가능한 방법(예: 데이터 완전 삭제(Wiping), 물리적 파쇄)으로 안전하게 파기한다. 7.2. 파기 절차 및 결과를 기록하고 관리한다.
8. **직원 교육 및 인식 제고 (Training and Awareness)** 8.1. 모든 임직원 및 계약 인력을 대상으로 연 1회 이상 개인정보 보호 및 정보 보안에 관한 의무 교육을 실시한다. 8.2. 신규 입사자에 대한 온보딩 프로세스에 보안 및 개인정보 보호 교육을 포함한다.
9. **침해 대응 (Incident Response)** 9.1. 개인정보 침해 사고 발생 시 신속하게 대응, 조사, 완화 및 복구하기 위한 공식적인 침해 대응 절차(IRP)를 수립하고 유지한다. 9.2. 침해 대응팀을 지정하고, 정기적인 훈련 및 모의 테스트를 수행한다.
10. **개발 보안 (Secure Development)** 10.1. 서비스 및 애플리케이션 개발 시 보안 코딩(Secure Coding) 원칙을 준수한다. 10.2. 개발, 테스트, 운영 환경을 분리하여 운영 데이터가 테스트 목적으로 사용되지 않도록 통제한다. 10.3. 코드 배포 전 보안 검토 및 테스트(SAST/DAST)를 수행한다.

[별첨 3] 승인된 하위 처리자 목록 (본 DPA 제 5.2 조에 따라 컨트롤러가 포괄적으로 승인한 하위 처리자)

1. **[AWS (Amazon Web Services, Inc.)]**
 - 처리 활동: 클라우드 인프라 제공 (서버 호스팅, 스토리지, 데이터베이스)
 - 소재지: 미국 (US), 아일랜드 (IE), 대한민국 (KR)
 - 적용되는 이전 메커니즘: SCC, BCR (Binding Corporate Rules)
2. **[Google LLC (Google Cloud Platform)]**
 - 처리 활동: 클라우드 인프라 및 데이터 분석 서비스
 - 소재지: 미국 (US), 핀란드 (FI), 싱가포르 (SG)
 - 적용되는 이전 메커니즘: SCC, BCR
3. **[SendGrid, Inc. (Twilio SendGrid)]**
 - 처리 활동: 트랜잭션 및 마케팅 이메일 발송 대행
 - 소재지: 미국 (US)
 - 적용되는 이전 메커니즘: SCC
4. **[Zendesk, Inc.]**
 - 처리 활동: 고객 서비스 지원 플랫폼(티켓팅 시스템) 제공
 - 소재지: 미국 (US), 아일랜드 (IE)
 - 적용되는 이전 메커니즘: SCC, BCR
5. **[Salesforce.com, Inc.]**
 - 처리 활동: CRM 플랫폼 기능 일부 제공
 - 소재지: 미국 (US)
 - 적용되는 이전 메커니즘: SCC, BCR
6. **[BetaSolutions Global Services (인도 지사)]**
 - 처리 활동: 24/7 기술 지원 및 시스템 모니터링 (L1 Support)
 - 소재지: 인도 (IN)
 - 적용되는 이전 메커니즘: (명시되지 않음 - 의도적 누락)
7. **[AnalyticsPro Ltd.]**
 - 처리 활동: 데이터 분석 및 리포팅 솔루션 제공
 - 소재지: 영국 (UK)
 - 적용되는 이전 메커니즘: 적정성 결정, SCC